

Agent Handbook — 02 Prior-Authorization

Assembles and submits prior-authorization requests for a provider — while the **coverage determination remains the payer's**. Maturity: Demonstrated + Deployable-by-design; production-readiness (CSV/CSA, IdP, live connectors, pen test, HITRUST) is the engagement; AWS BAA precedes any PHI.

Workflow + human gate

Detect a service requiring PA → run the payer's coverage-requirements discovery → gather clinical evidence from the chart → draft the PA against the rule set → ground every cited code/criterion → **suspend at the PA-Nurse gate** for clinical review → on approval, the agent submits the PA to the payer. **Named human gate:** PA Nurse. The agent submits the *request*; it never decides coverage.

Systems / connectors (with standards)

- **EHR / FHIR** — Epic / Oracle Health via Amazon HealthLake (FHIR R4): chart, orders, coverage.
- **Payer** — **Da Vinci CRD / DTR / PAS; X12 278** (PA request/response), **270/271** (eligibility), **276/277** (status). Aligned to CMS-0057-F FHIR PA APIs (Jan 1 2027).
- **Knowledge base** — payer coverage policy / criteria corpus for grounding.

Workforce roles to map in the IdP

PA_COORDINATOR (the PA-Nurse gate role), plus CLINICAL_STAFF / PROVIDER for clinical context. Map to custom:hpp_role.

Withheld authority (what it never does)

Submits the PA but never makes the coverage determination — that authority is the **payer's**. The agent assembles and (post-gate) submits the request; it does not approve, deny, or self-authorize coverage.

Deploy (fixture mode, no PHI)

```
scripts/build_lambdas.sh
scripts/deploy.sh 02-prior-authorization dev portable native
s3://my-cfn-staging/hpp 10.31.0.0/16
```

- Params: infra/cloudformation/params/02-prior-authorization.json · Terraform: terraform apply -var-file=envs/02-prior-authorization.tfvars
- VPC CIDR 10.31.0.0/16.

Human-gate smoke test

1. Sign in as a seeded PA_COORDINATOR (PA Nurse).

2. Drive a gated write (draft + submit a PA) → run **suspends** at the PA-Nurse gate; HITL item appears.
3. Approve → PA submission proceeds; approval written to the **append-only PHI-masked audit**.
4. Reject → submission does **not** proceed.
5. Attempt any payer determination tool (e.g. payer.issue_determination) → **denied by default**.

Key regs

HIPAA Privacy/Security, HITECH; **CMS-0057-F** (FHIR PA APIs by Jan 1 2027); payer medical-policy rules; CMS AI-in-UM guidance (payer side).

Go-live checklist

- ☐ AWS BAA + SI BAA executed; no PHI before both.
- ☐ IdP federated; PA_COORDINATOR / CLINICAL_STAFF / PROVIDER mapped to custom:hpp_role.
- ☐ Da Vinci CRD/DTR/PAS + X12 278/270/271/276/277 connectors validated against the live payer.
- ☐ CMS-0057-F FHIR PA-API path confirmed.
- ☐ Guardrail + grounding tuned to payer policy; CSV/CSA signed off; HITL SLA ratified.
- ☐ Pen test + HITRUST/SOC 2 evidence assembled; observability + runbooks adopted.